

THREAT INTELLIGENCE & IOC

Analisi di Cattura di Rete --- Identificazione Indicatori di Compromissione --- Proposte di Remediation e Contromisure

Studente:	Lorenzo Ventanni
Data:	05/06/2026
Corso:	Cybersecurity & Ethical Hacking @ EPICODE
Docente:	Paolo Rampino
Classificazione:	Riservato e Confidenziale

INDICE

N.	Sezione	Pag.
1	Obiettivo	3
2	Analisi della Cattura di Rete	3-5
3	Immediate Remediations	6
4	Contromisure Preventive	6-7
5	Conclusioni	7

1. Obiettivo

Basandosi sul file .pcapng in allegato, analizzare la cattura di rete effettuata con Wireshark attentamente e rispondere ai seguenti quesiti:

- Identificare ed analizzare eventuali IOC, ovvero evidenze di attacchi in corso;
- In base agli IOC trovati, fare delle ipotesi sui potenziali vettori di attacco utilizzati;
- Consigliare un'azione per ridurre gli impatti dell'attacco attuale ed eventualmente un simile attacco futuro.

2. Analisi della Cattura di Rete

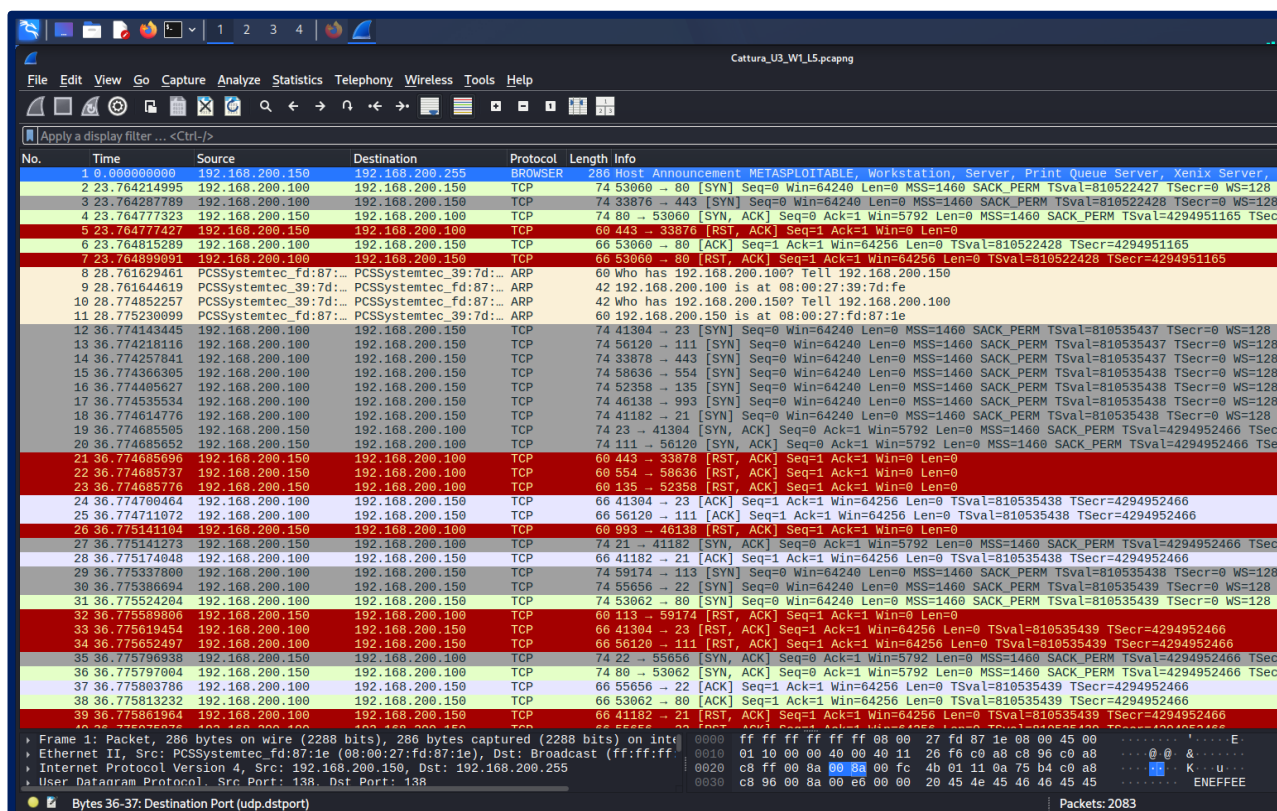


Figura 1 --- Screenshot delle prime 39 righe della cattura di rete aperta con Wireshark.

Per prima cosa, una volta aperto il file .pcapng con **Wireshark** e dando un rapido sguardo d'insieme al contenuto, mi rendo conto subito che si tratta di una serie di richieste **TCP Connect** complete (**Three-Way Handshake**) provenienti dall'IP **192.168.200.100 (attaccante)** e destinate all'IP **192.168.200.150 (target)**, entrambi appartenenti alla stessa subnet.

Il tutto è avvenuto in circa **100ms**.

Questo scenario mi fa subito pensare che sia stata effettuata una **scansione massiccia e mappatura delle porte** della macchina 192.168.200.150, con tool come **nmap o equivalenti**.

Facendo un passo indietro ed entrando più nel dettaglio, ho analizzato le prime righe della cattura, dalle quali ho potuto ricavare informazioni preziose:

1. **Riga 1** = La macchina vittima (192.168.200.150) è una macchina workstation/server Metasploitable;
2. **Righe 2-7** = noto due richieste TCP isolate alle porte 80 e 443 (HTTP e HTTPS), probabilmente un primo test preliminare prima dell'avvio della scansione massiccia. La porta 80 risulta aperta (TWH completato: SYN → SYN ACK → ACK) mentre la 443 risulta chiusa (TWH non completato, risposta RST ACK alla richiesta SYN);
3. **Righe 8-11** = qua noto uno scambio di ARP Request e Reply tra le due macchine, compatibile con la fase preliminare che precede lo scan effettivo quando si utilizzano tool come nmap, specialmente considerato il fatto che i due host si trovano nella stessa subnet: 192.168.200.0/24;

Procedendo con l'analisi approfondita, ho notato che, in risposta alle numerose richieste TCP SYN dell'IP attaccante, si verificano due scenari differenti:

1. **Porta OPEN** = la macchina target risponde con un SYN ACK, a cui segue l'ultimo passaggio del TWH, in cui la macchina attaccante risponde con un ACK, completando la connessione e determinando che quella determinata porta è di fatto aperta (connessione che interrompe subito dopo con un flag di reset RST ACK, una volta verificato ciò);
2. **Porta CLOSED/FILTERED** = la macchina target alla richiesta SYN risponde direttamente con un flag RST ACK, impedendo al TWH di completarsi e all'attaccante di stabilire una connessione su quella determinata porta, che risulterà chiusa o filtrata.

A questo punto, estrapolati il contesto e il tipo di attacco effettuato, sono voluto andare più a fondo identificando quante e quali porte del target sono state scansionate dall'attaccante, e, tra quelle, quali sono risultate aperte. Tutto ciò grazie ai seguenti filtri di Wireshark:

- 1) **`tcp.flags.syn && tcp.flags.reset == 0 && tcp.flags.ack == 0 && tcp.dstport > 1000`**
Con questo filtro ho ristretto il campo alle sole richieste SYN, specificando che il numero della porta di destinazione della richiesta fosse maggiore a 1000.
Grazie a ciò ho potuto affermare con certezza che l'attaccante ha effettuato uno scan sulle prime 1024 porte del target;
- 2) **`tcp.flags.syn == 0 && tcp.flags.reset == 0 && tcp.flags.ack == 1`**
Grazie a questo secondo filtro ho ristretto il campo a quelle connessioni in cui fosse presente solo il flag ACK, con l'obiettivo di scoprire quali porte fossero risultate aperte allo scan, ovvero solo quelle in cui il TWH fosse stato completato.
Di seguito, allego screenshot del risultato di questo filtro, con conseguente lista delle porte aperte sulla macchina 192.168.200.150.

In conclusione, posso affermare che l'attaccante ha eseguito un port scan aggressivo sull'IP 192.168.200.150, utilizzando un tool come nmap o simili. Il comando che ha eseguito con estrema probabilità è: **`nmap -sT -p 1-1024 192.168.200.150`**.

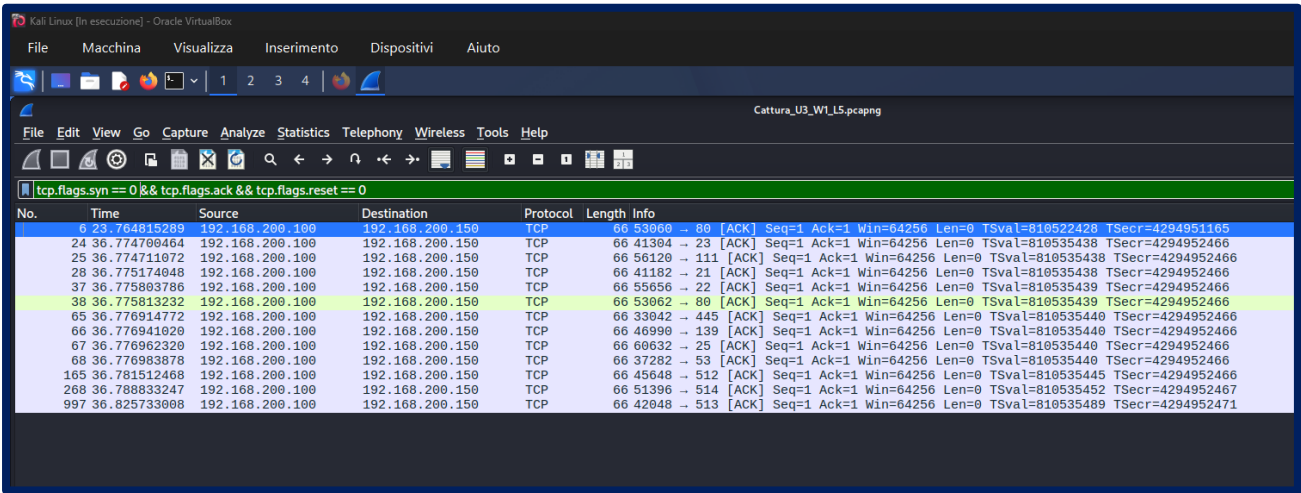


Figura 2 --- Lista di porte aperte sulla macchina target, che hanno completato il TCP TWH.

Porta	Servizio / Protocollo	Criticità
21	FTP - File Transfer Protocol.	Alta
22	SSH - Secure Shell.	Media
23	Telnet - Accesso remoto.	Critica
25	SMTP - Simple Mail Transfer Protocol.	Media
53	DNS - Domain Name System.	Media
80	HTTP - HyperText Transfer Protocol.	Media
111	rpcbind / Portmapper - Mappa i servizi RPC attivi sul sistema.	Alta
139	NetBIOS Session Service - Condivisione di file via SMB.	Alta
445	SMB - Server Message Block.	Critica
512	rexec - Remote Execution.	Critica
513	rlogin - Remote Login.	Critica
514	rsh - Remote Shell.	Critica

3. Immediate Remediations

I. **Implementazione di un firewall:**

Da quanto emerso durante l'analisi, il sistema target non è protetto da alcun firewall che possa filtrare il traffico e le connessioni in ingresso. Ciò rende il target vulnerabile ad attacchi di questo tipo (network scanner/Port mapper) e di molti altri.

È imperativa l'implementazione immediata di un firewall perimetrale con annessa regola di default-deny, per poi andare ad aprire con ulteriori regole ad hoc il traffico in ingresso solo ed esclusivamente alle porte strettamente necessarie, bloccando tutto il resto.

II. **Blocco dell'Indirizzo IP attaccante:**

Stabilito che l'IP 192.168.200.100 ha lanciato un port scanner verso il target, come best practice è consigliato bloccare immediatamente qualsiasi traffico in ingresso proveniente da quell'IP, per ricollegarsi anche al punto precedente.

In aggiunta, dato che sono state effettuate senza problemi più di 1000 richieste di connessione TCP nell'arco di 100ms, è consigliato aggiungere una regola di filtraggio del traffico in ingresso come segue:

bloccare qualsiasi IP che effettui più di x richieste in un y lasso di tempo.

4. Contromisure Preventive

I. **Chiusura porte 512, 513 e 514:**

I servizi rexec, rlogin e rsh hanno l'indice di criticità più alto, sono obsoleti e non hanno alcuna utilità o vantaggio operativo in un'ambiente moderno: trasmettono credenziali e dati in chiaro, non richiedono autenticazione e sono configurati di default per accettare connessioni basate sulla fiducia dell'indirizzo IP. Vanno disabilitati immediatamente.

II. **Sostituzione di Telnet con SSH:**

Il protocollo Telnet trasmette tutto il traffico in chiaro, è necessario sostituirlo con SSH, con autenticazione a chiave pubblica (chiusura porta 23 → porta 22 sicura).

III. **Sostituzione di FTP con FTPS (porta 21):**

FTP, come telnet, trasmette tutto il traffico in chiaro, è necessario sostituirlo con FTPS (FTP+TLS).

IV. **Patching e Update del servizio SMB (porta 445):**

Assicurarsi che il protocollo SMB sia aggiornato alla versione più recente, specialmente in relazione alla CVE critica denominata "EternalBlue" e simili. Qualora il servizio non fosse strettamente necessario si consiglia di disabilitarlo del tutto o filtrarlo tramite firewall.

V. **Disabilitazione di NetBIOS (porta 139):**

Protocollo obsoleto e datato, in ambienti moderni la condivisione delle risorse avviene già tramite SMB (porta 445). A meno che non sia strettamente necessario, si consiglia di disabilitarlo del tutto e di chiudere la porta 139.

- VI. **Restrizione dell'Accesso a rpcbind (porta 111):**
Si consiglia di implementare una regola firewall che limiti l'accesso alla porta 111 solo e solamente agli host che lo necessitano, oppure di disabilitarlo del tutto.
- VII. **Restrizione del Servizio DNS (porta 53):**
Si consiglia di configurare il DNS di modo da renderlo esclusivamente interno e irraggiungibile dall'esterno, filtrando la porta 53.
- VIII. **Migrazione da HTTP a HTTPS (porta 80 → porta 443):**
Con HTTP tutto il traffico web viene trasmesso in chiaro, si consiglia di migrare a HTTPS su porta 443, che utilizza connessioni cifrate TLS.

5. Conclusioni

Questa attività di analisi mi ha permesso di affrontare, toccando con mano, uno scenario di Threat Intelligence applicato al traffico di rete.

A partire dal file .pcapng fornito, ho proceduto con un'ispezione sistematica del contenuto, identificando gli Indicatori di Compromissione (IOC) presenti e ricostruendo, sulla base di essi, un quadro dello scenario di attacco avvenuto.

Il processo di analisi ha richiesto non soltanto la capacità di riconoscere pattern di traffico anomali, ma anche la comprensione approfondita dei protocolli coinvolti.

Gli IOC individuati hanno evidenziato una superficie d'attacco ampia e caratterizzata dalla presenza di più vettori critici, tra cui servizi di accesso remoto privi di cifratura, protocolli esposti senza restrizioni e configurazioni di rete che facilitano attività di ricognizione e un eventuale sfruttamento diretto delle vulnerabilità.

La combinazione di queste condizioni rappresenta, in un ambiente reale, uno scenario di rischio elevato che richiede intervento immediato.

Le remediations immediate e le contromisure preventive proposte integrano la mitigazione immediata delle criticità più urgenti con mitigazioni orientate a ridurre al minimo la superficie d'attacco e a impedire il ripetersi di scenari analoghi in futuro.

Nel complesso, l'esercitazione ha confermato come la capacità di leggere una cattura, estrarne informazioni significative e tradurle in azioni concrete costituisce una competenza operativa fondamentale.